

## MAPEO DETALLADO DE REQUISITOS NORMATIVOS

### Vinculación de Preguntas de Encuesta a NIS2, ISO 27001 y NIST CSF

#### TABLA 1: MAPEO ENCUESTA A NIS2 (DIRECTIVA 2022/2555 UE)

##### Medidas Técnicas y Organizacionales Obligatorias (Artículos 20-23)

| #  | Pregunta Encuesta                                         | Medida NIS2                                                | Artículo | Entidad | Requisito   |
|----|-----------------------------------------------------------|------------------------------------------------------------|----------|---------|-------------|
| 1  | P2.1:<br>¿Metodología formal de análisis de riesgos?      | Análisis y gestión de riesgos de ciberseguridad            | Art. 20  | EE, EI  | Obligatorio |
| 2  | P2.2:<br>¿Cuantificación monetaria de riesgos?            | Metodología de evaluación de impacto                       | Art. 20  | EE      | Obligatorio |
| 3  | P2.3: ¿Planes de tratamiento documentados?                | Medidas de mitigación de riesgos                           | Art. 20  | EE, EI  | Obligatorio |
| 4  | P3.1-P3.3:<br>¿Gestión de vulnerabilidades?               | Medidas de seguridad en sistemas y redes                   | Art. 21  | EE, EI  | Obligatorio |
| 5  | P5.1-P5.3:<br>¿SIEM y capacidad de detección?             | Capacidades de detección y respuesta a incidentes          | Art. 21  | EE      | Obligatorio |
| 6  | P6.1-P6.4:<br>¿Programa de capacitación en seguridad?     | Formación en ciberseguridad de altos dirigentes y personal | Art. 22  | EE, EI  | Obligatorio |
| 7  | P4.1-P4.2:<br>¿Pruebas de penetración regulares?          | Evaluación de efectividad de medidas (testing)             | Art. 21  | EE      | Obligatorio |
| 8  | P8.1-P8.2:<br>¿BCP y DR documentados?                     | Capacidad de continuidad de servicios                      | Art. 21  | EE, EI  | Obligatorio |
| 9  | P9.1-P9.2:<br>¿Evaluación de proveedores críticos?        | Seguridad de la cadena de suministro                       | Art. 21  | EE, EI  | Obligatorio |
| 10 | P10.1-P10.4:<br>¿Controles técnicos (MFA, cifrado, etc.)? | Medidas técnicas de seguridad integral                     | Art. 21  | EE, EI  | Obligatorio |

|    |                                                       |                                                         |             |        |             |
|----|-------------------------------------------------------|---------------------------------------------------------|-------------|--------|-------------|
| 11 | P7.1: ¿Designado responsable de notificación?         | Notificación de incidentes a autoridades (24-72h)       | Art. 23, 24 | EE, EI | Obligatorio |
| 12 | P5.3: ¿Registro y análisis de incidentes?             | Gestión de incidentes: registro, análisis, notificación | Art. 23     | EE, EI | Obligatorio |
| 13 | P1.2: ¿Comité de ciberseguridad con reportes a Junta? | Gobernanza: responsabilidad de órganos de dirección     | Art. 20     | EE, EI | Obligatorio |

**TABLA 2: MAPEO ENCUESTA A ISO/IEC 27001:2022**

**Cláusulas Obligatorias y Controles de Anexo A**

| Cláusula ISO                                          | Descripción                                  | Preguntas Encuesta                | Control Anexo A (si aplica)         |
|-------------------------------------------------------|----------------------------------------------|-----------------------------------|-------------------------------------|
| <b>Cláusula 4: Contexto de la Organización</b>        | Comprensión del contexto interno/externo     | P1.1, P1.2, P2.1                  | N/A (obligatorio para alcance)      |
| <b>Cláusula 5: Liderazgo y Compromiso</b>             | Liderazgo de directivos, políticas           | P1.2, P2.1, P7.3                  | A.5.1, A.5.2                        |
| <b>Cláusula 6: Planificación (Gestión de Riesgos)</b> | Análisis, evaluación, tratamiento de riesgos | P2.1, P2.2, P2.3                  | A.5.3 (Responsabilidad por riesgos) |
| <b>Cláusula 7: Recursos</b>                           | Personal, competencia, conciencia            | P1.2, P6.1-P6.4                   | A.6.1-A.6.3 (Personal y roles)      |
| <b>Cláusula 8: Operación</b>                          | Implementación de controles                  | P3.1-P3.3, P4.1-P4.2, P10.1-P10.4 | A.6 a A.8 (43 controles)            |
| <b>Cláusula 9: Evaluación del Desempeño</b>           | Monitoreo, medición, auditoría interna       | P4.2, P5.2-P5.3, P7.2             | A.5.11 (Auditoría interna)          |
| <b>Cláusula 10: Mejora Continua</b>                   | Acciones correctivas, no conformidades       | P2.3, P4.2, P8.1                  | A.5.2 (Mejora continua)             |

## Controles Anexo A Más Relevantes

| Control                                        | Dominio           | Preguntas Encuesta     | Importancia |
|------------------------------------------------|-------------------|------------------------|-------------|
| A.5.1: Políticas de seguridad                  | Gobernanza        | P7.3                   | Crítica     |
| A.5.2: Información de seguridad                | Gobernanza        | P7.3, P2.1             | Crítica     |
| A.5.3: Asignación de responsabilidades         | Gobernanza        | P1.2, P2.1             | Crítica     |
| A.5.11: Auditoría interna                      | Gobernanza        | P4.2, P7.2             | Alta        |
| A.6.1: Políticas de empleo                     | Personas          | P6.1, P6.2             | Alta        |
| A.6.2: Concienciación en seguridad             | Personas          | P6.1, P6.2, P6.3       | Crítica     |
| A.6.3: Responsabilidad del usuario             | Personas          | P6.1, P6.4             | Alta        |
| A.6.5: Control de acceso                       | Personas          | P10.1, P10.2           | Crítica     |
| A.6.6: Gestión de secretos                     | Personas          | P10.2                  | Alta        |
| A.8.1: Disposiciones de seguridad física       | Tecnología        | P10.3, P10.4           | Media       |
| A.8.2: Seguridad ambiental                     | Tecnología        | P10.3                  | Media       |
| A.8.3: Seguridad de operaciones                | Tecnología        | P5.1-P5.3, P10.3-P10.4 | Crítica     |
| A.8.4: Control de cambios                      | Tecnología        | P3.3, P10.1            | Alta        |
| A.8.5: Gestión de acceso remoto                | Tecnología        | P10.1                  | Alta        |
| A.8.6: Gestión de seguridad criptográfica      | Tecnología        | P10.2                  | Crítica     |
| A.8.7: Seguridad en TI del proveedor           | Cadena Suministro | P9.1, P9.2             | Alta        |
| A.8.8: Gestión de dispositivos                 | Tecnología        | P10.4                  | Alta        |
| A.8.9: Seguridad en la transmisión             | Tecnología        | P10.2, P10.3           | Crítica     |
| A.8.10: Gestión de información y documentación | Procesos          | P7.3, P8.2             | Alta        |
| A.8.11: Supresión de información               | Procesos          | P8.2                   | Media       |
| A.8.12: Cumplimiento                           | Procesos          | P7.1-P7.2              | Crítica     |

**TABLA 3: MAPEO ENCUESTA A NIST CYBERSECURITY FRAMEWORK v2.0**

**Cinco Funciones Core y Categorías**

| Función NIST          | Categoría                           | Descripción                                         | Preguntas Encuesta         |
|-----------------------|-------------------------------------|-----------------------------------------------------|----------------------------|
| <b>GOVERN (Nueva)</b> | Riesgos Organizacionales            | Entender riesgos estratégicos, regulatorios         | P2.1-P2.3, P7.1-P7.3, P1.2 |
| <b>GOVERN</b>         | Políticas, Procesos, Procedimientos | Directrices para gestión de seguridad               | P7.3, P2.1, P8.1           |
| <b>IDENTIFY</b>       | Gestión de Activos                  | Identificación y clasificación de activos           | P3.1, P9.2                 |
| <b>IDENTIFY</b>       | Gestión de Riesgos                  | Análisis sistemático de riesgos                     | P2.1, P2.2, P2.3           |
| <b>IDENTIFY</b>       | Gestión de Proveedores              | Evaluación de terceros                              | P9.1, P9.2                 |
| <b>PROTECT</b>        | Gobernanza                          | Roles, responsabilidades definidos                  | P1.2, P6.1                 |
| <b>PROTECT</b>        | Gestión de Personas                 | Concienciación, capacitación, reclutamiento         | P6.1-P6.4                  |
| <b>PROTECT</b>        | Gestión de Acceso                   | Autenticación, autorización, control                | P10.1, P10.2               |
| <b>PROTECT</b>        | Seguridad de Datos                  | Cifrado, protección de información                  | P10.2, P10.3               |
| <b>PROTECT</b>        | Operaciones Seguras                 | Integridad de sistemas, seguridad de procesos       | P3.3, P10.3, P10.4         |
| <b>DETECT</b>         | Detección de Anomalías              | Monitoreo continuo, alertas                         | P5.1-P5.3                  |
| <b>DETECT</b>         | Investigación de Eventos            | Análisis de anomalías                               | P5.3, P11.2                |
| <b>RESPOND</b>        | Gestión de Incidentes               | Planificación, análisis, comunicación de incidentes | P5.3, P8.1, P7.1           |
| <b>RESPOND</b>        | Mejora Después de Incidentes        | Post-mortem, lecciones aprendidas                   | P5.3, P4.2                 |
| <b>RECOVER</b>        | Planificación de Recuperación       | RTO/RPO, BCP, DR                                    | P8.1, P8.2                 |
| <b>RECOVER</b>        | Mejora de Resiliencia               | Aprendizaje y adaptación                            | P2.3, P8.1                 |

## Niveles de Madurez NIST CSF v2.0

| Nivel                      | Descripción                                         | Rango IGM | Características                                    |
|----------------------------|-----------------------------------------------------|-----------|----------------------------------------------------|
| 1 (Incomplete)             | Funciones de seguridad ad hoc                       | <1.2      | Sin procesos formales, reactividad pura            |
| 2 (Managed)                | Funciones reconocidas e implementadas informalmente | 1.2-2.4   | Procesos documentados pero inconsistentes          |
| 3 (Defined)                | Procesos documentados y comunicados                 | 2.4-3.6   | Estándares establecidos, cumplimiento regular      |
| 4 (Quantitatively Managed) | Procesos medidos y controlados                      | 3.6-4.8   | Métricas, automatización, análisis cuantitativo    |
| 5 (Optimized)              | Procesos en mejora continua con IA/ML               | >4.8      | Inteligencia artificial, predicción, adaptabilidad |

## TABLA 4: MAPEO ESPECIAL - MERCURY AVRQ A REQUISITOS NORMATIVOS

| Metodología Mercury                    | Requisito NIS2                              | Requisito ISO 27001                       | Beneficio                           |
|----------------------------------------|---------------------------------------------|-------------------------------------------|-------------------------------------|
| AVRQ (Cuantificación valor de activos) | Art. 20: Análisis de riesgos proporcionales | Cláusula 6: Risk assessment materializado | Justificación financiera ante Junta |
| ACET (Testing eficacia de controles)   | Art. 21: Validación de medidas técnicas     | Cláusula 9: Evaluación del desempeño      | Auditoría continua automática       |
| A.D.A.M. (Mapeo dinámico de activos)   | Art. 20: Identificación de activos críticos | Cláusula 6: Identificación de riesgos     | Descubrimiento continuo, cero gaps  |

## TABLA 5: MATRICES DE CONFORMIDAD POR DOMINIO

### Dominio 1: Gobernanza y Riesgos

| Pregunta                    | NIS2 Art. | ISO 27001 | NIST   | Criticidad |
|-----------------------------|-----------|-----------|--------|------------|
| P2.1: Metodología formal    | 20        | Cl. 6     | GOVERN | CRÍTICA    |
| P2.2: Cuantificación AVRQ   | 20, 23    | Cl. 6     | GOVERN | CRÍTICA    |
| P2.3: Planes de tratamiento | 20, 21    | Cl. 6     | GOVERN | CRÍTICA    |

**Requerimiento Mínimo Conformidad:** Puntuación  $\geq 3$  en todas las preguntas

**Requerimiento Óptimo:** Puntuación  $\geq 4$

### Dominio 2: Vulnerabilidades

| Pregunta                          | NIS2 Art. | ISO 27001    | NIST            | Criticidad |
|-----------------------------------|-----------|--------------|-----------------|------------|
| P3.1: Escaneo de vulnerabilidades | 21        | A.8.3, A.8.4 | PROTECT, DETECT | CRÍTICA    |
| P3.2: Priorización CVSS/EPSS      | 21        | A.5.3        | PROTECT         | ALTA       |
| P3.3: Gestión de parches          | 21        | A.8.4        | PROTECT         | CRÍTICA    |

**Benchmark España 2024:** Promedio sector 3.4/5

**Requerimiento NIS2:**  $\geq 3$  obligatorio,  $\geq 4$  recomendado

### Dominio 3: SIEM e Incidentes

| Pregunta                  | NIS2 Art. | ISO 27001 | NIST    | Criticidad      |
|---------------------------|-----------|-----------|---------|-----------------|
| P5.1-P5.2: SIEM y alertas | 21, 23    | A.8.3     | DETECT  | CRÍTICA para EE |
| P5.3: MTTR y respuesta    | 23        | A.8.3     | RESPOND | CRÍTICA         |

**Requerimiento NIS2 para EE:** Notificación  $< 24h$  (implica detección  $< 4h$ )

**Requerimiento NIS2 para EI:** Notificación  $< 24h$  (menos stringente)

### Dominio 4: Capacitación

| Pregunta                      | NIS2 Art. | ISO 27001 | NIST    | Criticidad |
|-------------------------------|-----------|-----------|---------|------------|
| P6.1-P6.2: Programa formal    | 22        | A.6.2     | PROTECT | CRÍTICA    |
| P6.3-P6.4: Phishing y reporte | 22        | A.6.2     | PROTECT | ALTA       |

**Requerimiento NIS2:** "Personal y en particular los altos dirigentes" debe recibir formación

**Benchmark España:** Tasa de reporte real promedio 25% (objetivo  $> 50\%$ )

## Dominio 5: Cumplimiento Normativo

| Pregunta                     | NIS2 Art. | ISO 27001 | NIST   | Criticidad         |
|------------------------------|-----------|-----------|--------|--------------------|
| P7.1: Conformidad NIS2       | 20-24     | Cl. 4     | GOVERN | CRÍTICA para EE/EI |
| P7.2: Certificación ISO      | N/A       | Cl. 4     | GOVERN | ALTA               |
| P7.3: Políticas documentadas | 20, 22    | Cl. 5     | GOVERN | CRÍTICA            |

## TABLA 6: SANCIONES REGULATORIAS (CONTEXTO DE CONFORMIDAD)

### Régimen Sancionador NIS2 en España

| Categoría                                    | Multa Máxima                     | Condiciones                                    |
|----------------------------------------------|----------------------------------|------------------------------------------------|
| Entidades Esenciales (incumplimiento grave)  | €10M o 2% de facturación global  | Medidas técnicas/org omitidas, CNCS notificado |
| Entidades Importantes (incumplimiento grave) | €7M o 1,4% de facturación global | Medidas técnicas/org omitidas, CNCS notificado |
| Incumplimiento de notificación (<72h)        | €500K-€5M (EE), €250K-€3M (EI)   | Notificación tardía                            |
| Falta de capacitación altos directivos       | €100K-€1M (EE)                   | Cuando auditoría lo evidencia                  |
| Daño reputacional (adicional GDPR)           | Hasta €20M (GDPR Art. 83)        | Si hay violación de datos personal             |

### Impacto Relativo por Dominio en Sanción

| Dominio Débil              | Sanción Probable               | Multiplicador |
|----------------------------|--------------------------------|---------------|
| Gobernanza y Riesgos (GR)  | Máximo (foundation)            | 3.0x          |
| SIEM (detección)           | Muy Alto (notificación tardía) | 2.5x          |
| Cumplimiento (políticas)   | Muy Alto                       | 2.5x          |
| Vulnerabilidades (gestión) | Alto (raíz de brechas)         | 2.0x          |
| Capacitación (empleados)   | Medio-Alto                     | 1.5x          |

**TABLA 7: CRONOGRAMA DE CONFORMIDAD ESPAÑA (Transposición NIS2)**

| Hito                                         | Fecha             | Estado                        | Implicación para Conformidad                |
|----------------------------------------------|-------------------|-------------------------------|---------------------------------------------|
| Aprobación del Anteproyecto de Ley           | Enero 2025        | ✓ Completado                  | Directivas claras en BOE                    |
| Entrada en vigor de la Ley Española          | Q1 2026           | Próxima (Estimado 31/01/2026) | Encuesta debe completarse antes             |
| Establecimiento de CNCS                      | Q2 2026           | Próximo                       | Designación de autoridad competente         |
| Plazo para registro de Operadores Esenciales | 6 meses post-ley  | Q3 2026                       | EE deben notificarse a CNCS                 |
| Primer ciclo de auditoría CNCS               | 12 meses post-ley | Q1 2027                       | Auditorías de conformidad de campo          |
| Multas operativas                            | Desde Q1 2027     | Inicio de aplicación          | Conformidad es obligatoria desde este punto |

**TABLA 8: MATRIZ DE CONFORMIDAD RÁPIDA (para Autodiagnóstico)**

¿Está mi organización conforme con NIS2/ISO 27001?

Responda Sí (✓) o No (X) a cada pregunta:

| Requisito                                                       | ✓ | X | Crítico              |
|-----------------------------------------------------------------|---|---|----------------------|
| ¿Existe análisis de riesgos formal (ISO 27005 o equivalente)?   |   |   | SÍ                   |
| ¿Se cuantifican riesgos en términos monetarios?                 |   |   | SÍ (NIS2 Art. 20)    |
| ¿Existen planes de tratamiento para todos los riesgos críticos? |   |   | SÍ                   |
| ¿Se realizan escaneos de vulnerabilidades regularmente?         |   |   | SÍ                   |
| ¿MTTR de vulnerabilidades críticas <14 días?                    |   |   | SÍ (NIS2 Art. 21)    |
| ¿Existe SIEM o equivalente detectando incidentes?               |   |   | SÍ (EE)              |
| ¿Capacitación en seguridad para altos directivos documentada?   |   |   | SÍ                   |
| ¿Procedimiento de notificación de incidentes <24h definido?     |   |   | SÍ                   |
| ¿BCP/DR probado en últimos 12 meses?                            |   |   | SÍ (NIS2 Art. 21)    |
| ¿Evaluación de proveedores críticos documentada?                |   |   | SÍ (NIS2 Art. 21)    |
| ¿Políticas de seguridad documentadas y comunicadas?             |   |   | SÍ                   |
| ¿Auditoría interna de ciberseguridad realizada anualmente?      |   |   | SÍ (ISO 27001 Cl. 9) |

#### Scoring:

- 10-12 Sí: Conforme (IGM  $\geq 4.0$ )

- **7-9 Sí:** Parcialmente conforme (IGM 2.5-3.9)
- **<7 Sí:** No conforme (IGM <2.5) → Acción inmediata requerida

## REFERENCIAS NORMATIVAS CLAVE

### Documentos Primarios

1. Directiva NIS2 (2022/2555/UE) - Artículos 20-24: Requisitos técnicos y organizacionales
2. ISO/IEC 27001:2022 - Cláusulas 4-10 y Anexo A (93 controles)
3. NIST CSF 2.0 - Funciones GOVERN, IDENTIFY, PROTECT, DETECT, RESPOND, RECOVER
4. RD Transposición NIS2 en España - Ley de Coordinación y Gobernanza de Ciberseguridad (Q1 2026)

### Documentos Secundarios (Orientación)

- ENISA: "NIS2 Implementing Guidance on Security Measures" (Junio 2024)
- AEPD: Guías GDPR Art. 32 (Medidas de seguridad)
- CCN-CERT: Catálogo de Medidas de Seguridad, Magerit v3.1
- ISO/IEC 27005:2022: Risk Management Standard
- NIST SP 800-30: Guía de Evaluación de Riesgos

### Fin del Mapeo de Requisitos Normativos

*Este documento mapea cada pregunta de la encuesta a requisitos legales específicos, permitiendo garantizar conformidad integral.*

*Versión 2.0 | Enero 2026*